

Web Investigation

Exercise: 1.1 | SQL-Injection Activity detected

Objectives:

The primary objective is to conduct a thorough investigation into a suspected SQL-injection Incident with the goal of identifying the source, scope, and impact of the attack.

Incident Details:

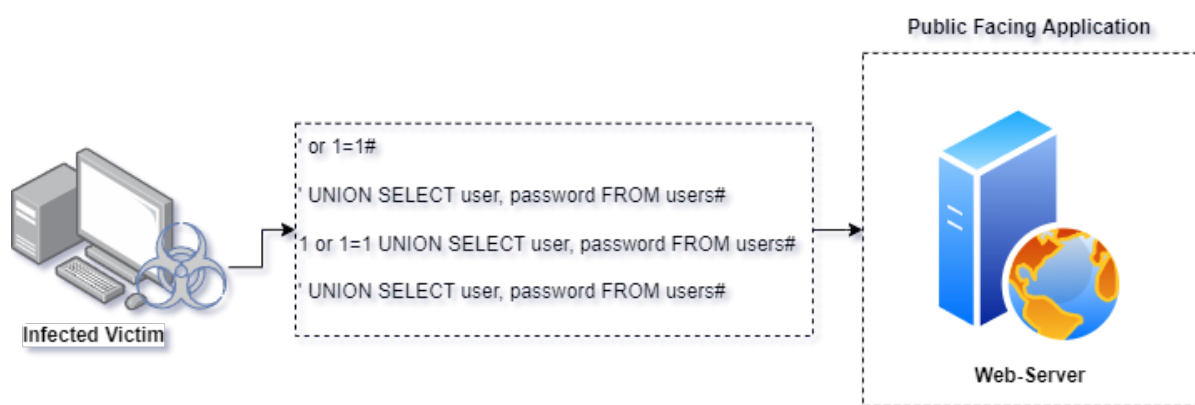
Investigate the suspicious SQL-Injection activity detected by the security monitoring systems. Investigate the web logs to identify the targeted IP, source, and potential impact.

Targeted URL:

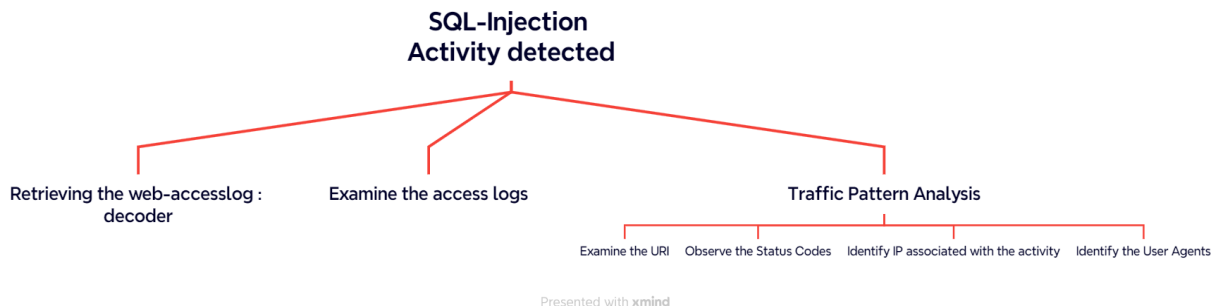
<http://192.168.117.190/prod/vulnerabilities/sqli>

About SQLi:

SQL injection is a type of web-based security vulnerability that occurs when an attacker is able to manipulate or inject malicious SQL code into a query. This can happen when input from an application, such as a web form or URL parameter.



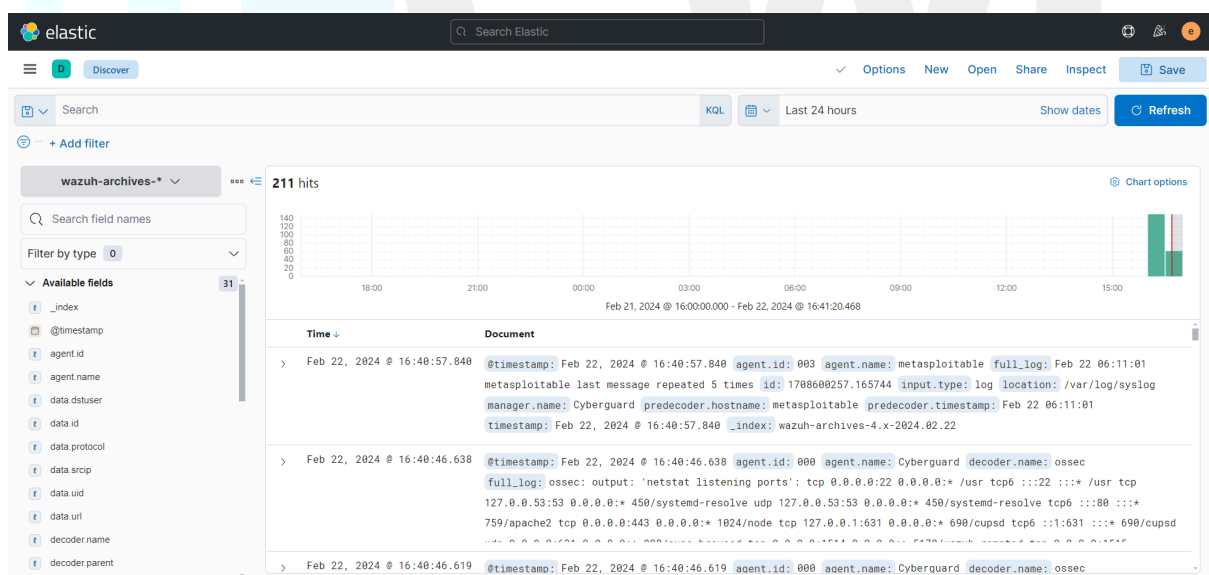
Investigation Mindmap:



Step:01

The first step of the investigation begins by analysing the web server logs. In our Blue Team Infrastructure, as we integrated the web log with our SIEM Wazuh : ELK solutions

Open the SIEM Console and navigate to the Analytics → Discover section



Note: Make sure that your are under **wazuh-archives** index

Step:03

Investigating SQL-Injection involves careful steps to ensure security and determine the nature and potential threats associated with the web logs.

1. Retrieving the web-accesslog : decoder
2. Examine the access logs
3. Traffic Pattern Analysis
 - a. Examine the URI
 - b. Observe the Status Codes
 - c. Identify IP associated with the activity
4. Observe the findings

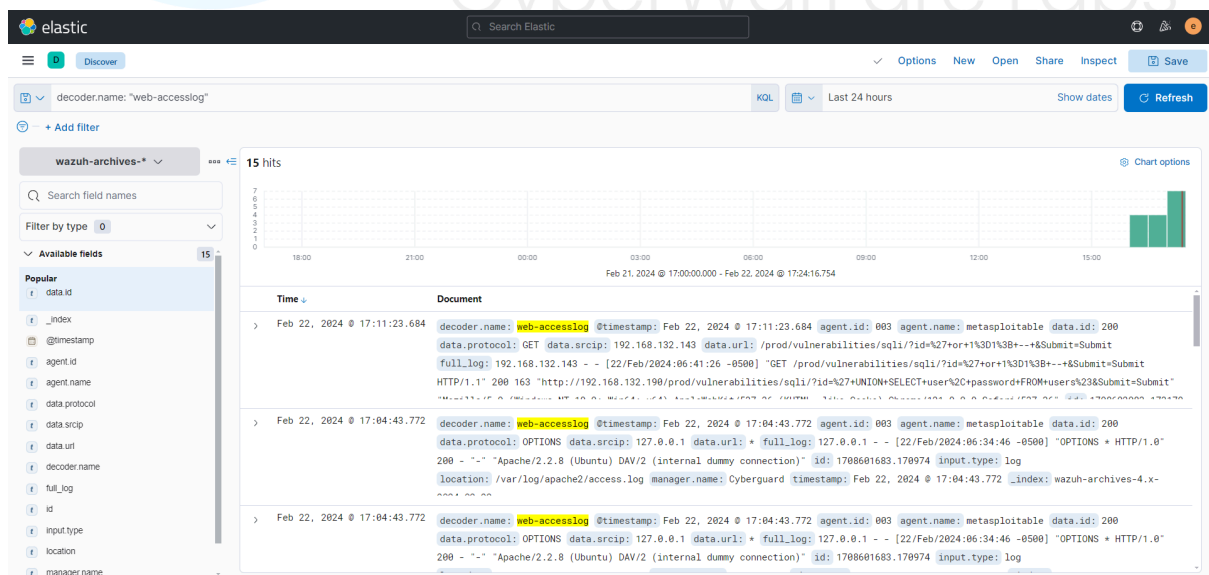
Retrieving the web-accesslog

Identifying and collecting the web access log allows us to extract certain logs for additional investigation.

Use the following command to obtain the web-access log.

Unset

```
decoder.name: "web-accesslog"
```



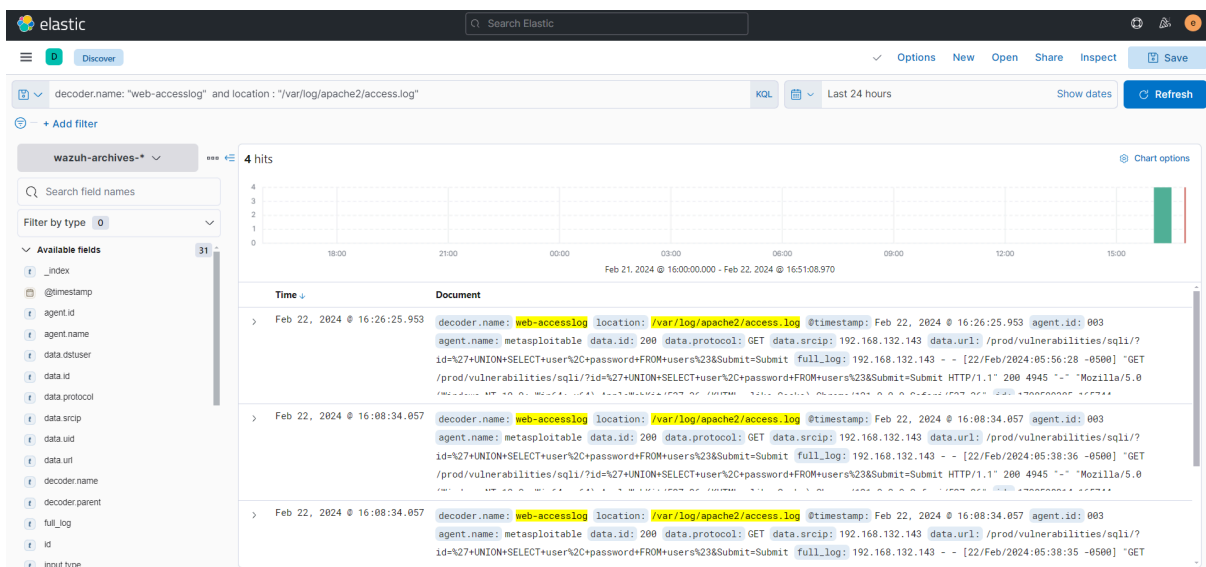
Decoders are the key components which are responsible for parsing raw logs into a structured format that can be easily analysed and understood by the system.

Examine the access logs

In general web server logs contain valuable information about incoming requests, errors, and server activities. It is recommended to check the access logs which record every request made to the server.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
```



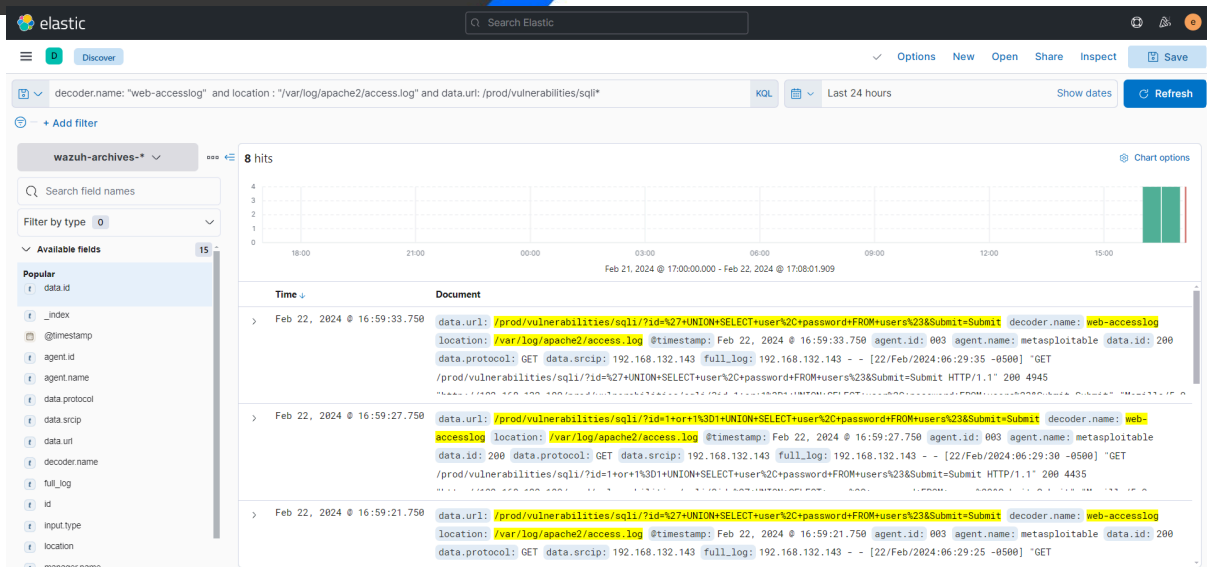
Note: Access logs provide details like IP addresses, requested files, status codes, etc.

Examine the URL

The next step is to observe the URL & URI request observed over the detected URL path, this helps us to identify the requests which are trying to be accessed by the attacker. Execute the below command and observe the findings.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
and data.url: /prod/vulnerabilities/sqli*
```



For better understanding, it is recommended to use the visualise option.

Top values of data.url	Count of recoi
/prod/vulnerabilities/sqli/?id=%27+UNION+SELECT+user%2C+password+FROM+users%23&Submit=Submit	6
/prod/vulnerabilities/sqli/?id=%27+or+1%3D1%23&Submit=Submit	1
/prod/vulnerabilities/sqli/?id=1+or+1%3D1+UNION+SELECT+user%2C+password+FROM+users%23&Submit=Sub...	1

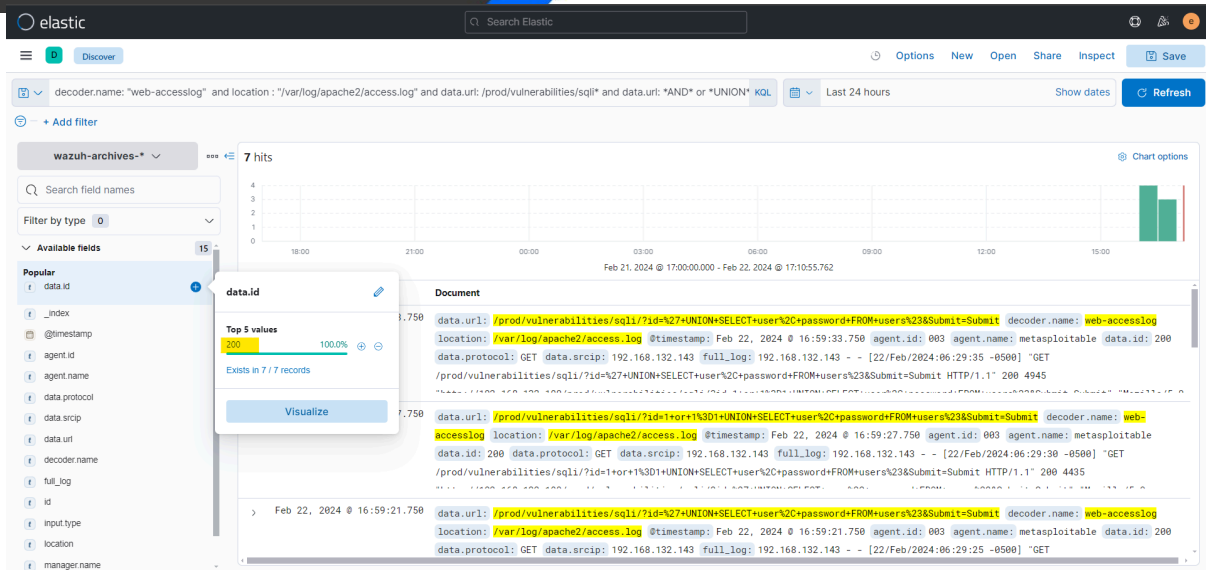
As per the above result, we observed multiple SQL commands over the web url request. In general, it's not considered as a normal activity when we observe a SQL command over the URL/URI requests

Examine the Status Codes

To validate or identify the suspicious activity it is recommended to check HTTP status codes of the observed logs. Execute the below query and observe the result.

Unset

```
decoder.name: "web-accesslog" and location: "/var/log/apache2/access.log"
and data.url: /prod/vulnerabilities/sqli* and data.url: *AND* or *UNION* or
*SELECT* and data.id: *
```



As per the observation we found a request with a status code 200.

Note: HTTP 200 generally indicates a successful HTTP request. This particular request appears when a client sends a GET request to the server, and the server successfully retrieves the requested resource, it responds with a status code of 200.

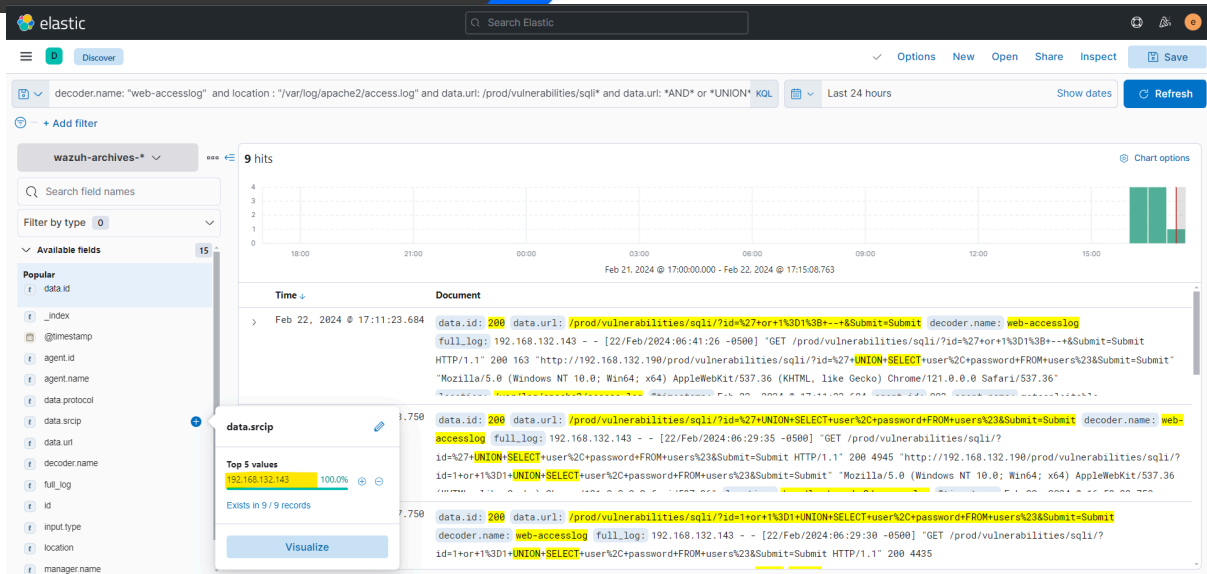
In case of SQL injection this specific pattern will be observed because the attacker will try executing multiple SQL commands over the web URL.

Identify IP associated with the activity

After Identifying the attack pattern it's recommended to look for IP addresses associated with the enumeration activity. Execute the below command and observe the finding.

Unset

```
decoder.name: "web-accesslog" and location: "/var/log/apache2/access.log"
and data.url: '/prod/vulnerabilities/sqli*' and data.url: '*AND*' or '*UNION*' or
*SELECT*' and data.id: 200 and data.scrip: *
```



In real case scenarios you might observe a lot more IP activity, it can be categories based on their legitimacy, behaviour and reputation.

Conclusion

The thorough examination of the incident has allowed you to understand the sequence of events leading up to the occurrence, identifying areas for improvement in processes and procedures.

Thank You!

Hope you have learnt a lot after practically completing
Blue Team Fundamentals Exercise.

If you like the investigation & the lab scenario,
feel free to tag us & share your achievement / progress
on social media platforms :)

For Enterprise Red Team / Blue Team / Purple Team
Cyber Range Labs / Training please email :
support@cyberwarfare.live

To know more visit at : <https://cyberwarfare.live>